SAVEETHA
INSTITUTE OF MEDICAL AND TECHNICAL SCIENCES
(Declared as Deemed to be University under Section 3 of UGC Act 1956)

# ASSIGNMENT 2

## QUESTIONS

**CO2:** Analyze public-key cryptosystem strategies using RSA and key exchange for encryption algorithms to strengthen information security.

CO2 Coverage: Symmetric key cryptosystems; Data Encryption Standard (DES); Triple DES (3DES); Blowfish; RC5; block ciphers; stream ciphers; block cipher modes of operation; public-key cryptosystems; RSA algorithm; key distribution and management; Diffie–Hellman key exchange; elliptic curve cryptography (ECC); introduction to quantum cryptography; number-theory foundations; RSA attacks and padding; digital signatures; hybrid encryption.

**Assignment Title:** Evaluate, Design and Defend a Secure Public-Key and Hybrid Cryptographic Strategy for a Multi-Site Healthcare Network (Total Marks: 50)

**Scenario — Secure Healthcare Data Exchange**

A healthcare network connects one central hospital with remote clinics that exchange patient records, prescriptions, diagnostic reports and billing data over public networks. The network contains low-resource devices, high-volume file transfers and multiple security requirements. The security team must select appropriate symmetric and public-key techniques, establish keys securely, authenticate exchanges and prepare for long-term cryptographic migration.

The system must:

- Protect stored and transmitted clinical records with confidentiality.
- Establish session keys over an observable public network.
- Provide authentication and integrity for security-sensitive exchanges.
- Support large files without performing expensive public-key encryption on every data block.
- Remain practical for constrained clinics while allowing secure migration as threats and technology change.

**Design Challenge**

During peak operation the network expands to many remote sites. An attacker can observe traffic, attempt a man-in-the-middle attack during unauthenticated key exchange, exploit weak RSA parameters, and analyse repeated ciphertext patterns. Management also requires a migration plan for future quantum threats. Re-evaluate the original design using your mathematical and experimental evidence.

## Q1 – Symmetric Cryptosystem Selection and Modes of Operation (7 Marks)

**Problem Context – Protecting Clinical Records**

The network must compare classical symmetric choices before using public-key techniques. Evaluate DES, 3DES, Blowfish and RC5, together with the distinction between block and stream ciphers and the principal block-cipher modes.

**Your Challenge**

- Explain the structure, block size, key characteristics and round operation of DES, 3DES, Blowfish and RC5.
- Implement or simulate at least three of these algorithms on student-created test data and verify encryption/decryption.
- Explain the difference between block and stream ciphers and identify an appropriate use for each.
- Explain ECB, CBC, CFB, OFB and CTR, including IV/nonce requirements, pattern leakage, error propagation and parallelism.
- Demonstrate why ECB can reveal repeated plaintext patterns and why IV/nonce reuse is dangerous.
- Compare operation count and execution time for increasing message sizes.

**Evaluation**

Rank DES, 3DES, Blowfish and RC5 for the scenario, identify legacy limitations, and recommend where a block or stream construction would be appropriate. Do not treat a larger key space alone as proof of security.

Evidence Expected: Algorithm comparison, mode comparison, test results, pattern/IV demonstration and a justified recommendation.

## Q2 – Number-Theory Engine and Prime Selection for RSA (6 Marks)

**Problem Context – RSA Key Generation**

RSA depends on modular arithmetic, modular inverses, modular exponentiation and the generation of suitable primes.

**Your Challenge**

- Implement GCD, Extended Euclidean Algorithm, modular inverse and fast modular exponentiation.
- Compare trial-search inverse with Extended Euclid and naive repeated multiplication with square-and-multiply.
- Explain Euler's totient function and the condition gcd(e, φ(n)) = 1.
- Compare trial division, Fermat and Miller–Rabin on safe toy candidates, including Carmichael numbers such as 561, 1105 and 1729.
- Record modular multiplications, division/loop steps and false acceptance results.
- Explain how prime density affects the number of candidates tested.
- Re-evaluate the methods when the RSA modulus grows from classroom-sized values toward 1024-, 2048- and 3072-bit engineering requirements.

**Evidence Expected:** Mathematical derivations, pseudocode, designed test cases, operation counts, primality-test evidence and engineering decision.

**Q3 – RSA Encryption/Decryption, Weaknesses and Padding (7 Marks)**

**Problem Context – Online Banking Message Protection**

A bank uses textbook RSA for short tokens. The security team must determine whether correct decryption is sufficient evidence of secure encryption.

**Your Challenge**

- Generate RSA keys and implement C = M^e mod n and M = C^d mod n.
- Verify one hand-checkable RSA example.
- Test deterministic encryption, repeated-message encryption, small-message/small-exponent behaviour, boundary messages and invalid parameter choices.
- Explain how factoring n permits recovery of φ(n) and d.
- Implement or simulate trial-division and Fermat factorisation on weak toy moduli, including close primes and a small factor.
- Explain why RSA key length alone does not guarantee security and why weak key generation can undermine a large modulus.

- Explain RSA padding, especially OAEP, and how randomisation prevents structural weaknesses of textbook RSA.

**Inquiry**

Predict each test before execution, compare prediction with evidence, and state the limitations of classroom-scale factoring experiments.

Evidence Expected: Correct RSA implementation, attack traces, factoring evidence, padding analysis and security conclusions.

**Q4 – Diffie–Hellman Key Exchange, Authentication and Key Management (7 Marks)**

**Problem Context – Secure Link Between Remote Clinics**

Two clinics must establish a shared session key over a network that an attacker can fully observe, without having a pre-shared secret.

**Your Challenge**

- Derive the Diffie–Hellman procedure from $(g^a)^b \equiv (g^b)^a \pmod{p}$.
- Develop pseudocode showing private values, public values and the shared-key computation.
- Test a small hand-verifiable example and a larger toy configuration.
- Measure the legitimate computation and a brute-force discrete-log attack as p grows.
- Demonstrate an active man-in-the-middle attack against unauthenticated Diffie–Hellman.
- Explain how digital signatures or certificates authenticate the exchanged values and defeat the attack.
- Design a key-distribution and key-management policy covering generation, storage, rotation, revocation, compromise recovery and session-key lifetime.

**Evidence Expected:** Protocol derivation, message-sequence diagram, implementation, MITM demonstration, growth analysis and key-management policy.

**Q5 – ECC and Public-Key Strategy Comparison (5 Marks)**

**Problem Context – Constrained Devices**

Remote medical devices need public-key security with manageable key size, computation and communication overhead.

**Your Challenge**

- Explain the mathematical basis of elliptic-curve public-key

cryptography and demonstrate a toy ECC key-generation/key-agreement example.
- Compare RSA, Diffie–Hellman and ECC in key size, computational cost, bandwidth and deployment considerations.
- Explain why ECC can provide comparable security with smaller public-key material than traditional RSA-style parameters.
- Identify implementation requirements such as secure randomness, parameter validation and protected private keys.
- Recommend a public-key strategy for constrained devices and justify it using the experimental evidence from Q2–Q4.

**Evidence Expected:** Toy ECC example, RSA/DH/ECC comparison table and a defended recommendation.

## Q6 – Digital Signatures, Hybrid Encryption and Quantum-Cryptography Readiness (7 Marks)

### Problem Context – Large Confidential Document Exchange

The healthcare network must transfer large files with confidentiality, integrity and sender authenticity. The team is comparing direct public-key protection with hybrid encryption and must also consider future quantum threats.

### Your Challenge

- Design a digital-signature process using hash-then-sign and explain signing and verification.
- Compare RSA, DSA/DSS and ECDSA at the conceptual level with respect to keys, signing/verification, randomness and security assumptions.
- Design hybrid encryption: encrypt the large payload with a random symmetric session key, then protect or establish that session key using RSA or Diffie–Hellman; authenticate the exchange.
- Test tampering of the file, signature and protected session key.
- Compare direct RSA encryption of large data with hybrid encryption using operation counts and file-size growth.
- Explain the basic principle of quantum key distribution/quantum cryptography and how eavesdropping can be detected.
- Explain why sufficiently capable quantum computers threaten RSA and ECC and propose a migration/readiness strategy without claiming that quantum cryptography itself replaces ordinary cryptographic key management.

### Deployment Decision

Choose a practical architecture for the healthcare network and justify the

choice using performance, security, key-management burden and long-term risk.
**Evidence Expected:** Signature flow, hybrid-encryption design, tamper tests, growth comparison, quantum-security explanation and final architecture.

## DAY-4 DESIGN CHALLENGE

### Q7 – Diagnose, Redesign and Validate the Complete Cryptographic Strategy (11 Marks)

Review the evidence from Q1–Q6 and identify one significant computational or security limitation that becomes important as message volume, key size, number of clinics or attacker capability increases.

### A. Diagnose the Bottleneck or Weakness (2 Marks)

● Identify the operation or missing security property responsible for the limitation.

● Explain how its cost or risk changes with input/key size or repeated use.

● Use measured operation counts or attack evidence from earlier tasks.

### B. Define the Design Objective (1 Mark)

State a measurable redesign objective, such as reducing public-key operations, preventing a man-in-the-middle, reducing key-management exposure, detecting weak keys, or improving secure bulk-data handling.

### C. Design the Revised Strategy (3 Marks)

Develop a revised architecture using the appropriate combination of symmetric encryption, secure modes, RSA/DH/ECC, digital signatures, key management and hybrid encryption. Explain the mathematical/security property exploited, operations reduced, additional state or keys required, and new trade-offs.

### D. Integrate Quantum Readiness (1 Mark)

Identify which RSA/ECC dependencies are threatened by future quantum computing and define a migration approach. Explain separately what quantum key distribution can contribute and what it cannot replace.

### E. Predict, Implement and Validate (2 Marks)

Predict the improvement before implementation. Compare original and redesigned solutions using operation counts, attack steps, key-management events, verification results and execution time where useful.

Verify that the redesign preserves required functionality.

**F. Defend the Final Design (2 Marks)**

Defend the final decision against the original alternatives. Discuss residual risks, deployment cost, usability, key compromise, MITM attacks, weak keys, large-file performance and long-term quantum risk.

**Evidence Expected:** Diagnosis, measurable objective, revised architecture/protocol, prediction, comparable experimental evidence and final engineering defence.

**MARK DISTRIBUTION**

| Question | Assessed Area | Marks |
|---|---|---|
| Q1 | Symmetric cryptosystems, DES/3DES/Blowfish/RC5, block/stream ciphers and modes | 7 |
| Q2 | Number theory, modular arithmetic and prime selection | 6 |
| Q3 | RSA encryption/decryption, attacks, weak keys and padding | 7 |
| Q4 | Diffie–Hellman, MITM authentication and key management | 7 |
| Q5 | ECC and RSA/DH/ECC comparison | 5 |
| Q6 | Digital signatures, hybrid encryption and quantum readiness | 7 |
| Q7 | Day-4 integrated diagnose, redesign and validation | 11 |
| TOTAL | | 50 |

**Submission Requirements**

Submit your assignment report containing Q1–Q7 evidence, source code for student-implemented core algorithms, raw experimental data, tables/graphs and protocol/message-sequence diagrams. Libraries may be used for cross-checking standard primitives, but the mathematical core and experiments must be your own.

All attack demonstrations must use only student-created toy parameters and test data. Do not use classroom code to protect real patient data.

**Assessment Verification**

Students may be asked to explain algorithm design, source code, test data, mathematical predictions, experimental results, security analysis and the Day-4 redesign during a brief verification/viva. Both the reasoning and the evidence must be understood by the student.

- Algorithmic and protocol design
- Source code
- Test-data and key-set design
- Experimental results
- Predictions
- Security analysis
- Design Challenge

during a brief verification discussion/viva. The student should therefore be able to explain and defend the evidence submitted as their own work.

**Overall Assessment Expectation**

This assignment does not primarily assess your ability to reproduce textbook cryptosystems.

It assesses your ability to:

*Predict → Design → Implement → Measure → Analyse → Attack → Evaluate → Diagnose → Redesign → Validate*

Your conclusions and design decisions must be supported by your own mathematical reasoning and experimental evidence.